

INCIDENT RESPONSE LIFECYCLE REPORT: BRIGHTTECH APT

Prepared by: Solomon Mwaura
Date: February 25, 2026
Status: Final Analysis

1. Preparation

Based on Step 1: Preparation requirements.

Before the incident occurred, BrightTech established several key capabilities to ensure readiness. This included the deployment of EDR (Endpoint Detection and Response) agents across all workstations and the implementation of a centralized SIEM (Security Information and Event Management) platform for log aggregation. The incident response team was trained on specific APT playbooks, and communication channels (Out-of-Band) were pre-defined to prevent attackers from monitoring internal response efforts.

2. Detection and Analysis

Based on Step 2: Detection and Analysis requirements.

The incident was detected when the SIEM flagged anomalous outbound traffic to an uncategorized domain (*tech-support-portal.net*) on port 443. Initial analysis confirmed several indicators of compromise (IOCs):

- **Alert Source:** Network egress logs showing high-volume data transfer.
- **Suspected Malware:** A malicious executable disguised as a system update (*sys_patch_v2.exe*).
- **Scope of Infection:** Three workstations in the Finance Department and one server in the R&D VLAN.
- **Attack Origin:** Initial access traced back to a spearphishing link targeting an HR employee.

3. Containment, Eradication, and Recovery

Based on Step 3: Mitigation/Recovery requirements.

Phase	Actions Taken	Outcome
Containment	Isolated affected workstations from the production network. Blocked the malicious C2 domain at the firewall and proxy level.	Prevented further data exfiltration and stopped lateral movement to the production database.

Phase	Actions Taken	Outcome
Eradication	Performed deep scans to remove <code>sys_patch_v2.exe</code> . Reset all compromised user credentials and rotated service account keys.	Ensured no persistent backdoors remained on the network.
Recovery	Restored Finance workstations from verified clean backups. Monitored the R&D server for 48 hours for any signs of reinfection.	Business operations resumed within 24 hours of the containment phase.

4. Post-Incident Activity (Lessons Learned)

Based on Step 4: Post-Incident Activity requirements.

Following the resolution of the incident, the IR team identified several areas for improvement:

- **Root Cause:** Lack of email sandboxing allowed the spearphishing link to reach the end-user.
- **Detection Gap:** The time-to-detect was 4 hours; this needs to be reduced through automated alerting for newly registered domains.
- **Action Item:** Implement mandatory security awareness training focusing on "typosquatting" and URL verification for all departments.
- **Infrastructure Change:** Accelerate the transition to a Zero Trust architecture to further limit lateral movement capabilities.